

Rendu individuel - Mahamadou DIACOUMBA - V1

Detection SOC, regles, Playbooks et REX incidents

Rendu individuel - Mahamadou DIACOUMBA - V1

Informations generales

Champ | Valeur
Nom | DIACOUMBA
Prenom | Mahamadou
Projet | Mise en place d'un SOC externalise pour un reseau d'audioprothesistes
Role | Analyste SOC / detection / playbooks / REX incidents
Equipe | Yvan FOCSA, Youssef GUERNIOU, Kilyan FELIX, Mahamadou DIACOUMBA

1. Presentation de mon role

Dans ce projet, mon role est de construire la partie detection et reponse incident. Cela signifie definir des scenarios d'attaque realistes, adapter ou creer des regles de detection, tester les alertes dans le SIEM, rediger les playbooks et produire les retours d'experience des incidents simules.

Le SOC ne doit pas seulement collecter des logs. Il doit permettre a un analyste de comprendre rapidement ce qui se passe, d'evaluer la criticite et d'appliquer une procedure de reponse. Mon travail se concentre donc sur la transformation des logs en decisions operationnelles.

2. Contributions principales

Contribution | Description
Scenarios d'attaque | Definition des cas d'usage SOC prioritaires.
Regles de detection | Participation a la creation et au test des regles Wazuh.
Alertes | Validation des alertes Daylight detectees.
Playbooks | Redaction des procedures brute force, phishing, acces patient, privileges et USB.
REX incidents | Analyse des incidents simules et des actions de reponse.
Demo SOC | Preparation de la sequence attaque -> detection -> investigation -> reponse.

3. Travail realise

J'ai commence par identifier les menaces les plus pertinentes pour un reseau d'audioprothesistes : phishing, execution suspecte, brute force, acces anormal aux dossiers patients, elevation de privileges et usage USB. Ces scenarios couvrent a la fois les postes utilisateurs, les acces reseau, les applications metier, les donnees sensibles et les comptes privileges.

J'ai ensuite travaille sur la logique de detection. Les regles Wazuh du sprint 01 permettent de documenter sept alertes : execution PowerShell suspecte, brute force sur acces distant, acces anormal aux dossiers patients, modification d'un groupe privilege, usage USB, phishing et scan reseau. Ces alertes sont documentees dans les preuves techniques du projet.

Enfin, j'ai formalise les playbooks de reponse. Chaque playbook precise les etapes de qualification, les controles a realiser, les actions possibles et les preuves a conserver. Cette partie est importante car elle montre la posture professionnelle du SOC.

4. Perspectives d'evolution de la solution

La premiere evolution serait d'ameliorer la qualite des regles. Pour un MVP, les detections sont volontairement

simples et lisibles. En production, il faudrait ajouter plus de corrélation, des seuils adaptés, des exceptions légitimes et une réduction des faux positifs.

La deuxième évolution serait d'ajouter une solution de gestion d'incidents comme TheHive. Cela permettrait de transformer une alerte Wazuh en ticket, de suivre les actions, d'assigner un analyste et de conserver l'historique de traitement.

La troisième évolution serait d'intégrer une source de threat intelligence comme MISP. Les alertes pourraient être enrichies avec des indicateurs connus : IP malveillantes, domaines suspects, hashes ou campagnes de phishing.

5. Limites techniques rencontrées

La principale limite est que les incidents sont simulés. Cela permet de maîtriser la démo, mais cela reste différent d'une attaque réelle ou les événements sont incomplets, bruyants et parfois ambigus.

Une autre limite concerne les faux positifs. Une règle trop large peut déclencher beaucoup d'alertes non pertinentes, tandis qu'une règle trop stricte peut manquer une attaque. L'équilibre entre détection et bruit est un vrai sujet SOC.

Enfin, certains scénarios comme l'USB ou la messagerie sont difficiles à reproduire parfaitement sans vrai poste Windows ou serveur mail. Il faut donc expliquer clairement ce qui est simulé et ce qui serait fait en production.

6. Analyse critique personnelle

Je pense que la détection doit toujours être reliée à une action. Une alerte qui n'a pas de playbook ou de contexte est difficilement exploitable. C'est pour cela que les scénarios du projet sont construits avec une logique complète : événement, alerte, qualification, réponse et REX.

Avec du recul, j'aurais pu commencer encore plus tôt par rédiger les hypothèses de compromission. Cela aurait facilité l'écriture des règles et des playbooks, car chaque détection aurait été reliée à un risque précis.

Je retiens aussi que la preuve est essentielle. Pour une soutenance, il faut pouvoir montrer une alerte, expliquer pourquoi elle est importante et présenter la procédure associée.

7. Défis rencontrés

- choisir des scénarios réalistes et démontrables ;
- produire des alertes visibles dans Wazuh ;
- éviter des règles trop génériques ;
- relier chaque alerte à un risque métier ;
- rédiger des playbooks simples mais professionnels ;
- produire un REX clair pour chaque incident.

8. Forces personnelles mobilisées

Force | Application

Esprit SOC | Raisonnement attaque, détection, investigation et réponse.

Analyse | Qualification des alertes et interprétation des logs.

Méthode | Structuration des playbooks.

Sens du risque | Priorisation des incidents critiques.

Communication | Explication des scénarios dans la vidéo et le rapport.

9. Points d'amélioration personnels

Je dois approfondir la corrélation d'événements. Les alertes individuelles sont utiles, mais un SOC mature doit pouvoir relier plusieurs signaux : par exemple phishing, exécution PowerShell, connexion sortante et

modification de compte.

Je dois aussi progresser sur l'écriture de règles plus robustes, notamment avec des decoders plus propres, des niveaux de criticité cohérents et des exceptions pour limiter les faux positifs.

Enfin, je dois travailler la présentation des incidents. Un bon analyste SOC doit expliquer rapidement ce qui s'est passé, pourquoi c'est important, quelles actions ont été prises et quel risque reste ouvert.

10. Competences developpees

- definition de scenarios d'attaque ;
- creation et test de regles de detection ;
- analyse d'alertes SIEM ;
- redaction de playbooks SOC ;
- production de REX incidents ;
- comprehension du lien entre logs et risques metier ;
- preparation d'une demo de detection.

11. Axes d'amelioration pour de futurs projets

Pour un futur projet, je construirais une matrice detection des le debut avec les colonnes suivantes : scenario, source de logs, condition de detection, regle, criticité, faux positifs possibles, playbook et preuve attendue.

Je mettrais aussi en place des tests de detection reproductibles. Chaque regle devrait avoir un log de test normal et un log de test malveillant.

Enfin, j'ajouterais une phase d'amelioration continue apres chaque incident simule : ce que la regle a bien detecte, ce qu'elle a manque, ce qu'il faut ajuster.

12. Conclusion personnelle

Ma contribution porte principalement sur la detection et la reponse incident. J'ai travaille sur les scenarios, les alertes, les playbooks et les REX. Cette partie permet de montrer que le SOC ne se contente pas de stocker des logs : il produit des informations exploitables et guide la reaction.

La suite logique consisterait a renforcer les regles, remplacer les captures de demonstreur par des captures Wazuh live si possible, enrichir les REX et preparer la demonstration de l'analyse SOC pour la video MVP.